

☒ 1. Risk Management in Information Security

Risk Management in InfoSec is a systematic process of:

- Identifying,
- Assessing, and
- Controlling risks to an organization's information assets.

It ensures that **threats** and **vulnerabilities** do not compromise the **confidentiality, integrity, or availability** of data.

☒ Steps in Risk Management:

1. Asset Identification

-

What needs protection? (e.g., data, systems, networks)

2.

Threat Identification

-

What could happen? (e.g., malware, DDoS, insider threat)

3.

Vulnerability Assessment

-

What weaknesses exist? (e.g., unpatched software)

4.

Risk Analysis

-

Qualitative (Low/Med/High) or

-

Quantitative (in financial terms)

5.

Risk Evaluation

- Determine acceptable risk level

6.

Risk Treatment Options:

- **Avoid** (eliminate the risk)
- **Transfer** (insurance, outsourcing)
- **Mitigate** (apply controls)
- **Accept** (live with it)

7.

Monitoring and Review

- Continuously improve based on feedback

☒ 2. Exposure and Countermeasure

☒ Exposure

Exposure refers to the **extent of potential damage** that can occur if a vulnerability is exploited.

Example:

- A hospital storing unencrypted patient data is **exposed** to data breach risks.

☒ Countermeasure (Security Control)

A countermeasure is a safeguard or defense mechanism that reduces risk by:

- Reducing vulnerabilities
- Blocking threats
- Minimizing impacts

Types of Controls:

Control Type	Example
Preventive	Firewall, Antivirus, ACLs
Detective	IDS, logs, SIEM
Corrective	Backups, patching, failover systems
Deterrent	Warning banners, policies
Compensating	Temporary workaround controls

☒ Key Security Tools: Firewall & DMZ

☒ 3. Firewall

A **firewall** is a **security device or software** that monitors and filters **incoming and outgoing network traffic** based on **security rules**.

It acts as a **barrier** between trusted and untrusted networks.

☒ Key Functions:

- Packet filtering
- Stateful inspection

- Proxy services
- Logging and alerting

☒ **Types of Firewalls:**

Type	Description
Packet Filtering	Filters packets based on IP, port, protocol
Stateful Inspection	Keeps track of connection state
Proxy Firewall	Acts as intermediary; inspects traffic at application layer
Next-Gen Firewall (NGFW)	Includes DPI, intrusion prevention, application awareness

❏ 4. Demilitarized Zone (DMZ)

A DMZ (De-Militarized Zone) is a **buffer zone** between an organization's internal network and the public internet.

It hosts **public-facing services** (e.g., web, mail, DNS) and protects the internal network if those services are compromised.

❏ Benefits of DMZ:

- Limits attacker access
- Segregates public servers from private network
- Allows granular access control

❏ Typical DMZ Configuration:

text

Copy code

Internet | [Firewall 1] | [DMZ] --> Web Server, Mail Server | [Firewall 2] | Internal Network (Sensitive data)

☒ 5. Two Methods of Implementing Firewalls

Method 1: Single Firewall with 3-legged DMZ

- One firewall with **three interfaces**:
 - WAN (Internet)
 - DMZ (public services)
 - LAN (private network)

Advantage: Cost-effective

Disadvantage: Single point of failure

Method 2: Dual Firewall DMZ

- Uses two separate firewalls:
 - First: between Internet and DMZ
 - Second: between DMZ and Internal Network

Advantage: More secure

Disadvantage: More complex and expensive

☒ Summary Table

Term	Description
Risk Management	Process to identify, evaluate, and control risks
Exposure	Degree of potential loss from a threat
Countermeasure	Any action that mitigates risk
Firewall	Filters traffic based on rules
DMZ	Isolated network segment for public services
Firewall Methods	Single firewall (3-legged), dual firewall (layered security)